

Modelo integral de encuesta de ciberseguridad, continuidad de negocio y ciber-resiliencia

Versión base. Adaptable a sector, tamaño de organización y ámbito territorial.

Escala recomendada para la mayoría de preguntas:

- a) Situación muy incipiente → 0
- b) Situación básica → 1
- c) Situación intermedia → 2
- d) Situación avanzada/madura → 3

Sección 0. Información general y perfil de la organización

ORG-01. Tipo de organización principal

Selecciona la opción que mejor describa a tu organización.

- a) Administración pública (estatal, autonómica, local)
- b) Empresa privada
- c) Entidad del sector financiero
- d) Entidad del sector sanitario o social
- e) Otro (indicar)

ORG-02. Tamaño aproximado de la organización (personas)

- a) Menos de 50
- b) De 50 a 249
- c) De 250 a 999
- d) 1.000 o más

ORG-03. Alcance geográfico principal de la organización

- a) Local / municipal
- b) Autonómico / regional
- c) Nacional
- d) Multinacional

ORG-04. Rol principal de la persona que responde

- a) Dirección / Gerencia / Alta dirección
- b) CISO / Responsable de seguridad / Responsable de TI
- c) Responsable de continuidad de negocio / BCM / Riesgos
- d) Perfil técnico (operaciones, SOC, desarrollo, etc.)
- e) Otro (indicar)

ORG-05. ¿Cómo describirías, a grandes rasgos, el nivel actual de madurez en ciber-resiliencia de tu organización?

- a) «Sobrevivimos a base de ingenio y buena voluntad; la formalidad llegará otro día.»
- b) «Tenemos piezas importantes montadas, pero aún falta encajarlas y afinarlas.»
- c) «Contamos con procesos, roles y herramientas razonablemente consolidados, aunque mejorables.»
- d) «Somos más resilientes que un junco: flexibles, preparados y con métricas que lo demuestran.»

Sección 1. Gobierno y estrategia (GOV)

GOV-01. Existencia de una estrategia formal de ciberseguridad y/o ciber-resiliencia

- a) No existe una estrategia formal; nos guiamos por el instinto y las urgencias.
- b) Existe un documento de estrategia, pero vive más en la intranet que en la práctica.
- c) Hay una estrategia aprobada, con cierta alineación entre áreas, aunque no siempre se sigue al pie de la letra.
- d) Contamos con una estrategia clara, actualizada y desplegada, con objetivos, métricas y seguimiento periódico.

GOV-02. Integración entre ciberseguridad y continuidad de negocio (BCM)

- a) Cada una vive en su universo: se cruzan sólo cuando hay incidentes graves.
- b) Se coordinan puntualmente para auditorías, reguladores o grandes sustos.
- c) Comparten riesgos, participantes y algunas métricas, pero aún hay silos.
- d) Forman un único programa integrado de ciber-resiliencia, con gobierno y reporting comunes.

GOV-03. Implicación de la alta dirección en ciberseguridad y continuidad

- a) Aparece en las presentaciones, pero rara vez en las reuniones.
- b) Se interesa cuando hay incidentes o temas regulatorios urgentes.
- c) Recibe informes periódicos y toma decisiones relevantes de forma reactiva.
- d) Patrocina de forma activa la resiliencia, fija objetivos y revisa resultados con regularidad.

GOV-04. Claridad de roles y responsabilidades en ciberseguridad y BCM

- a) La respuesta oficial es «depende»; la extraoficial, «ya veremos quién se ocupa».
- b) Existen descripciones básicas de rol, pero con solapamientos y zonas grises.
- c) Los roles están definidos y son conocidos, aunque no siempre se respetan.
- d) Roles y responsabilidades están claramente definidos, comunicados y se revisan cuando cambian las estructuras.

GOV-05. Presupuesto específico para ciberseguridad y continuidad

- a) No hay presupuesto claramente identificado: se improvisa según incendios.
- b) Hay partidas dispersas y se negocian caso a caso.
- c) Existe un presupuesto definido, aunque justo y a veces insuficiente para el plan.
- d) El presupuesto está alineado con los riesgos y el plan de resiliencia, con visión plurianual.

GOV-06. Coordinación entre áreas técnicas, negocio y cumplimiento

- a) Cada área vive su propia serie; sólo hay crossover en crisis.
- b) Existen comités o grupos, pero con asistencia irregular y foco limitado.
- c) La coordinación es aceptable, con reuniones regulares y acuerdos básicos.
- d) Hay foros de gobierno efectivos donde negocio, TI, seguridad, BCM y cumplimiento toman decisiones conjuntas.

Sección 2. Gestión de riesgos y vulnerabilidades (RISK, VULN)

2.1. Gestión de riesgos

RISK-01. Existencia de un marco formal de gestión de riesgos de ciberseguridad/TIC

- a) No existe un marco formal; se evalúan riesgos de forma ad-hoc.
- b) Hay una metodología en papel, poco aplicada.
- c) Se aplica una metodología conocida (por ejemplo, basada en normas ISO o marcos internos) con cierta regularidad.
- d) La gestión de riesgos está plenamente integrada en la toma de decisiones y enlaza con BCM, inversiones y prioridades.

RISK-02. Frecuencia de actualización del análisis de riesgos

- a) Sólo cuando pasa algo grave o lo pide un auditor.
- b) Aproximadamente cada 2–3 años.
- c) Al menos una vez al año o ante cambios relevantes.
- d) Con revisión continua y formalización anual, incorporando datos de incidentes, vulnerabilidades y cambios de entorno.

RISK-03. Alcance del análisis de riesgos

- a) Cubre sólo algunos sistemas o proyectos aislados.
- b) Se centra en TI, dejando fuera procesos de negocio y terceros.
- c) Incluye activos clave de negocio y principales dependencias TI.
- d) Cubre procesos críticos, activos, personas, tecnología y cadena de suministro de forma sistemática.

RISK-04. Criterios de priorización de riesgos

- a) Básicamente por intuición o por quien levanta la voz más alto.
- b) Hay una matriz básica de probabilidad/impacto, sin mucho refinamiento.
- c) Se aplican criterios más elaborados (impacto económico, reputacional, regulatorio) para priorizar.
- d) La priorización está alineada con el apetito de riesgo aprobado, y se apoya en datos (incidentes, indicadores, escenarios de pérdida).

RISK-05. Integración riesgos-BCM (relación con el análisis de impacto)

- a) El análisis de impacto, cuando existe, va por un lado y el de riesgos por otro.
- b) Se hacen referencias cruzadas de forma puntual.
- c) Riesgos y BIA se alinean en procesos críticos, aunque todavía hay huecos.
- d) El BIA y el análisis de riesgos están plenamente conectados y se mantienen coordinados en el tiempo.

2.2. Gestión de vulnerabilidades

VULN-01. Inventario de activos para la gestión de vulnerabilidades

- a) El inventario vive en leyendas urbanas y hojas sueltas de cálculo.
- b) Existe, pero está incompleto o desactualizado.
- c) Es razonablemente completo para sistemas críticos.
- d) Es completo, actualizado y se usa activamente para priorizar escaneos y parches.

VULN-02. Proceso de escaneo y gestión de vulnerabilidades

- a) Se realizan escaneos ad-hoc cuando alguien se acuerda.
- b) Hay escaneos periódicos, pero sin seguimiento sistemático de remediación.
- c) Existe un proceso definido de escaneo y cierre de vulnerabilidades con plazos orientativos.
- d) El proceso está formalizado, monitorizado por métricas (SLA de parcheo) y ligado a la criticidad del activo.

VULN-03. Integración de vulnerabilidades en el análisis de riesgo y BCM

- a) Lo técnico va por libre; los riesgos se describen en términos muy genéricos.
- b) Sólo se consideran vulnerabilidades críticas puntuales.
- c) Las vulnerabilidades relevantes se reflejan en el mapa de riesgos.
- d) Existe una trazabilidad clara entre vulnerabilidades críticas, riesgos corporativos y decisiones de continuidad.

VULN-04. Métricas de exposición a vulnerabilidades

- a) No se miden; se comenta «tenemos muchas, pero no sabemos cuántas».
- b) Se recogen datos básicos (número de vulnerabilidades abiertas), sin análisis.
- c) Se monitorizan tendencias (por criticidad, tiempo de remediación).
- d) Las métricas se usan de forma activa para priorizar acciones y justificar inversiones.

Sección 3. Pruebas de penetración (PENT)

PENT-01. Frecuencia de realización de pruebas de penetración

- a) Nunca, o sólo antes de grandes auditorías o certificaciones.
- b) De forma puntual (cada 2–3 años o según proyectos).
- c) Al menos una vez al año en sistemas/servicios clave.
- d) Con un plan anual estructurado, coordinado con cambios relevantes y nuevos servicios.

PENT-02. Alcance de las pruebas de penetración

- a) Muy limitado (un par de aplicaciones o sistemas visibles).
- b) Incluye algunos sistemas críticos, pero deja fuera parte importante del entorno.
- c) Cubre la mayoría de los activos críticos, aunque no siempre toda la cadena.
- d) Incluye TI, OT (si aplica), servicios expuestos, aplicaciones críticas y, cuando procede, ingeniería social.

PENT-03. Gestión de hallazgos de pruebas de penetración

- a) Se guarda el informe en una carpeta respetable, pero poco visitada.
- b) Se corrigen algunas vulnerabilidades graves, sin seguimiento sistemático.
- c) Hay un proceso formal de plan de acción y seguimiento.
- d) Los hallazgos alimentan procesos de mejora, reajuste de riesgos y revisión de BCM cuando aplica.

PENT-04. Coordinación entre pruebas técnicas, SIEM y BCM

- a) Cada cual a lo suyo: pentesters, SOC y BCM apenas se hablan.
- b) Se comparte información de forma esporádica.
- c) Existe cierto flujo de información para priorizar casos y escenarios.
- d) Hay una coordinación estructurada: los resultados de pruebas técnicas influyen en reglas de detección, ejercicio de crisis y actualización de planes de continuidad.

Sección 4. Monitorización y gestión de eventos de seguridad (SIEM)

SIEM-01. Implantación de capacidades de monitorización y SIEM

- a) La monitorización es principalmente manual o reactiva.
- b) Existen algunas herramientas de log, sin correlación centralizada.
- c) Hay un SIEM o plataforma equivalente en operación, con alcance parcial.
- d) Contamos con un SIEM maduro y un SOC interno o externo que opera 24x7 (o según necesidades).

SIEM-02. Cobertura de fuentes de eventos (logs)

- a) Se recogen pocos logs y sin una política clara.
- b) Se recogen logs de algunos sistemas críticos.
- c) Se cubren los principales sistemas, redes y aplicaciones críticas.
- d) Existe una estrategia definida de logging y el SIEM cubre de forma consistente la superficie de ataque relevante.

SIEM-03. Capacidad de detección temprana de incidentes

- a) La mayoría de incidentes se detectan por el usuario final o por terceros.
- b) El SIEM ayuda a detectar algunos incidentes, con cierto retraso.
- c) Se detecta una proporción relevante de incidentes de forma proactiva.
- d) La detección es mayoritariamente proactiva y se apoya en casos de uso bien definidos y revisados.

SIEM-04. Integración entre SIEM, gestión de incidentes y continuidad

- a) El SIEM avisa, pero la coordinación más allá de TI es limitada.
- b) Existen procedimientos básicos de escalado.
- c) La gestión de incidentes está alineada con la activación de ciertos planes (por ejemplo, comunicación, DRP).
- d) La activación de BCM/BCP está claramente ligada a umbrales de incidentes definidos en el SIEM.

SIEM-05. Uso de métricas en monitorización

- a) No se miden tiempos ni volúmenes de forma sistemática.
- b) Se monitorizan algunos indicadores básicos (número de alertas, incidentes).
- c) Se miden MTTD, MTTR y otros indicadores de rendimiento.
- d) Las métricas se revisan con la dirección y se usan para mejorar procesos y justificar inversiones.

Sección 5. Continuidad de negocio y recuperación (BCM, DRP)

BCM-01. Existencia de un programa formal de continuidad de negocio (BCM)

- a) No existe programa formal; hay buena voluntad y algo de improvisación organizada.
- b) Hay algún documento de BCP, poco conocido y menos probado.
- c) Existe un programa definido, con alcance razonable, aunque con lag en actualizaciones.
- d) El programa BCM está plenamente implantado, revisado y conectado con riesgo, TI y negocio.

BCM-02. Análisis de impacto en el negocio (BIA)

- a) No se ha realizado BIA, o se hizo hace tanto que vive en la prehistoria.
- b) Existe un BIA básico para algunos servicios.
- c) Hay un BIA formal para los procesos y servicios críticos, revisado puntualmente.
- d) El BIA es completo, se actualiza periódicamente y se usa para decisiones de priorización y diseño de soluciones.

BCM-03. Definición de objetivos de recuperación (RTO/RPO)

- a) No están definidos, o viven sólo en las mentes de unas pocas personas.
- b) Se han definido para algunos servicios, sin demasiado detalle.
- c) Se han definido para la mayoría de los servicios críticos.
- d) Están claramente definidos, acordados con negocio y reflejados en soluciones y contratos.

BCM-04. Cobertura de planes de continuidad (BCP)

- a) Muy limitada (uno o dos procesos emblemáticos).
- b) Cubre parte de los procesos críticos.
- c) Cubre la mayoría de procesos críticos, aunque con calidades irregulares.
- d) Cubre de forma sistemática todos los procesos y servicios críticos identificados en el BIA.

BCM-05. Pruebas y ejercicios de continuidad

- a) Raras o inexistentes; confiamos en «ya nos apañaremos» llegado el momento.
- b) Se realizan pruebas aisladas (por ejemplo, recuperación de backups).
- c) Hay ejercicios planificados anualmente, aunque a veces con alcance reducido.
- d) Existe un programa estructurado de ejercicios y simulacros, con participación multidisciplinar y revisión posterior.

BCM-06. Inclusión de escenarios de ciberincidentes (ransomware, DDoS, caída de proveedor cloud) en el BCM

- a) No se contemplan de forma específica.
- b) Se mencionan de forma genérica como «fallos TIC».
- c) Se han modelizado algunos escenarios ciber relevantes.
- d) Los principales escenarios ciber están incorporados en planes, ejercicios y decisiones de diseño.

BCM-07. Capacidad de operación en modo degradado

- a) El plan oficial es «rezar para que vuelva»; no hay procedimientos alternativos claros.
- b) Algunos equipos conocen apaños locales para seguir operando.
- c) Existen procedimientos definidos para operar manualmente o en modo reducido.
- d) La operación en modo degradado está documentada, probada y coordinada entre áreas.

DRP-01. Planes de recuperación de TI (DRP)

- a) Inexistentes o meramente aspiracionales.
- b) Existen para algunos sistemas críticos.
- c) Cuentan con documentación y se han probado parcialmente.
- d) Están completos, alineados con RTO/RPO y probados de forma regular.

DRP-02. Backups y su gestión

- a) «Hacemos backups», pero pocos podrían explicar cómo, dónde y cada cuánto.
- b) Hay políticas básicas de backup, con pruebas esporádicas de restauración.
- c) Los backups siguen políticas claras y se prueban regularmente.
- d) Hay estrategia de copias segregadas, protección frente a ransomware y restauraciones probadas en escenarios realistas.

DRP-03. Coordinación DRP-BCP-ciberseguridad

- a) Cada plan va por libre, si es que existe.
- b) Existen referencias cruzadas informales.
- c) DRP y BCP están razonablemente alineados y coordinados con ciberseguridad.
- d) Existe una arquitectura de resiliencia integrada donde DRP, BCP y seguridad forman un todo coherente.

Sección 6. Capacitación, cultura y concienciación (AWARE)

AWARE-01. Programa de formación y concienciación en ciberseguridad

- a) Algún curso puntual y muchas buenas intenciones.
- b) Se ofrece formación básica, sin demasiada continuidad.
- c) Existe un programa anual estructurado, con distintos niveles y perfiles.
- d) El programa es continuo, adaptado a roles y se revisa según incidentes y cambios tecnológicos.

AWARE-02. Formación específica en continuidad de negocio y gestión de crisis

- a) Muy limitada o inexistente.
- b) Se imparte para unos pocos perfiles clave.
- c) Cubre a la mayoría de responsables de procesos críticos.
- d) Forma parte regular del desarrollo de mandos intermedios y directivos.

AWARE-03. Simulaciones y ejercicios prácticos (phishing, crisis, etc.)

- a) Nunca, o se hicieron una vez y se recuerdan como una leyenda.
- b) Se realizan campañas puntuales (por ejemplo, de phishing simulado).
- c) Hay ejercicios anuales de simulación combinando aspectos técnicos y organizativos.
- d) Las simulaciones son regulares, variadas y sus resultados se usan para ajustar formación y procesos.

AWARE-04. Cultura de reporte de incidentes

- a) Se evita reportar; «mejor que nadie se entere».
- b) Hay canales formales, poco utilizados.
- c) Se reportan incidentes con cierta normalidad.
- d) Existe una cultura positiva de reporte, sin miedo excesivo a la culpa, y se hace seguimiento constructivo.

AWARE-05. Medición de la eficacia de la formación

- a) La medición se basa en «parece que estuvo bien».
- b) Se usan encuestas de satisfacción.
- c) Se miden cambios de comportamiento (por ejemplo, clics en phishing, uso de canales de reporte).
- d) La eficacia se evalúa con indicadores antes/después y se incorporan mejoras continuas.

AWARE-06. Implicación visible de la dirección en la cultura de seguridad y resiliencia

- a) Escasa; el mensaje es más bien «ya os apañaréis».
- b) Apoyos puntuales (correos, actos simbólicos).
- c) Mensajes regulares y participación en algunas actividades.
- d) Liderazgo activo, con ejemplo visible y coherente.

Sección 7. Métricas, indicadores y ROI (MET, ROI)

MET-01. Disponibilidad de indicadores de ciberseguridad y continuidad

- a) Pocos o ninguno; se navega más por sensaciones que por datos.
- b) Existen algunos indicadores técnicos dispersos.
- c) Hay un cuadro de mando básico que combina indicadores técnicos y de negocio.
- d) El cuadro de mando es completo, se revisa periódicamente y se alinea con objetivos estratégicos.

MET-02. Cobertura de indicadores de resiliencia (RTO, RPO, MTTR, etc.)

- a) Apenas se miden, o lo hacen solo algunos equipos.
- b) Se recogen datos de forma irregular.
- c) Se miden sistemáticamente para los principales servicios críticos.
- d) Se miden, analizan y utilizan para ajustar capacidades y compromisos.

MET-03. Uso de indicadores adelantados (simulacros, exposición a vulnerabilidades, etc.)

- a) El foco está casi todo en indicadores «post-mortem» (incidentes ya ocurridos).
- b) Hay algunos indicadores proactivos, poco sistematizados.
- c) Se miden y revisan tanto indicadores proactivos como reactivos.
- d) Los indicadores adelantados son clave en la gestión diaria y en la planificación.

MET-04. Frecuencia de reporte a la alta dirección

- a) Esporádicamente, cuando toca «dar explicaciones».
- b) Al menos una vez al año.
- c) Con frecuencia trimestral.
- d) Con reportes regulares (mensuales o trimestrales) e integración en comités de riesgo.

MET-05. Vinculación de indicadores con objetivos y planes

- a) Poca o ninguna; los indicadores viven en sus propias tablas.
- b) Algunos indicadores se vinculan a objetivos de área.
- c) Hay objetivos definidos (por ejemplo, reducir MTTR, aumentar cobertura de BCP).
- d) Los objetivos se revisan, los indicadores se ajustan y se toman decisiones en base a ellos.

ROI-01. Evaluación económica de iniciativas de ciberseguridad y resiliencia

- a) Se decide «por fe» o por presión externa, sin números claros.
- b) Se hacen estimaciones puntuales para proyectos grandes.
- c) Se realizan análisis coste-beneficio razonables para las principales iniciativas.
- d) Existe un marco sistemático de evaluación económica (incluido ROI) usado en la priorización.

ROI-02. Uso de escenarios de pérdida (downtime, sanciones, reputación)

- a) Se consideran de forma informal.
- b) Se emplean en algunos casos (por ejemplo, para justificar grandes proyectos).
- c) Se utilizan escenarios estructurados en la gestión de riesgos.
- d) Se combinan en modelos más completos (por ejemplo, con apoyo de finanzas o actuariado).

ROI-03. Comunicación del valor de la resiliencia a la dirección

- a) Se percibe como centro de coste inevitable.
- b) A veces se conectan proyectos con incidentes evitados.
- c) Se comunica de forma más estructurada (indicadores, casos de uso).
- d) La resiliencia se percibe y se presenta como un habilitador de negocio y reputación.

Sección 8. Proveedores y ecosistema (SUP, ECO)

SUP-01. Gestión de riesgos de terceros y proveedores TIC

- a) Se firma el contrato y se confía en la providencia.
- b) Se revisan aspectos básicos de seguridad en la selección inicial.
- c) Hay un proceso formal para evaluar riesgos de terceros críticos.
- d) Existe un marco sistemático de gestión de riesgos de terceros, con seguimiento periódico.

SUP-02. Requisitos de continuidad y ciberseguridad en contratos

- a) Escasos o genéricos; «esto lo pondrá la parte legal».
- b) Se incluyen cláusulas de seguridad estándar.
- c) Se especifican requisitos mínimos de continuidad (RTO, RPO, pruebas).
- d) Los contratos recogen requisitos claros y se revisan periódicamente a la luz de incidentes y cambios normativos.

SUP-03. Participación de proveedores en ejercicios de crisis y continuidad

- a) Nula o anecdótica.
- b) Alguna participación puntual cuando el proveedor se presta.
- c) Participación en ejercicios significativos con proveedores clave.
- d) Participación estructurada de terceros en ejercicios, con lecciones aprendidas conjuntas.

SUP-04. Visibilidad sobre la cadena de suministro digital (subproveedores, servicios cloud, etc.)

- a) Limitada; sabemos con quién firmamos, pero no siempre quién está detrás.
- b) Se identifican algunos subproveedores críticos.
- c) Existe un mapa básico de dependencias relevantes.
- d) Se mantiene y actualiza un mapa detallado de la cadena de suministro digital, con evaluación periódica.

ECO-01. Participación en iniciativas sectoriales o nacionales de ciberseguridad/ciber-resiliencia

- a) No participamos, o lo hacemos de forma muy esporádica.
- b) Estamos suscritos a algunas listas o foros de información.
- c) Participamos activamente en redes y grupos de trabajo.
- d) Desempeñamos un rol de referencia (liderazgo, contribuciones destacadas) en el ecosistema.

ECO-02. Coordinación con autoridades y CERTs (nacionales, sectoriales)

- a) Básicamente reactiva; se contacta sólo en incidentes graves.
- b) Existen canales definidos, aunque poco usados.
- c) La coordinación es razonable, con intercambio periódico de información.
- d) La relación es fluida y estructurada, con participación en ejercicios conjuntos y notificación ágil.

ECO-03. Posición de la organización en el ecosistema de ciber-resiliencia

- a) Observador pasivo: vemos la película desde la butaca.
- b) Participante ocasional: salimos en algunos capítulos.
- c) Actor habitual: colaboramos con otros de forma regular.
- d) Referente: ayudamos a marcar tendencias, buenas prácticas y estándares.

Sección 9. Comentarios finales

Espacio abierto para matices, aclaraciones y todo aquello que no cabe cómodamente en una opción de respuesta cerrada.

- Comentarios generales sobre la encuesta.
- Aspectos que consideras críticos y que quizá no se han recogido.
- Sugerencias para próximas iteraciones.

Fin del cuestionario. Gracias por tu tiempo, tu paciencia y tu sentido del humor aplicado a la ciber-resiliencia.